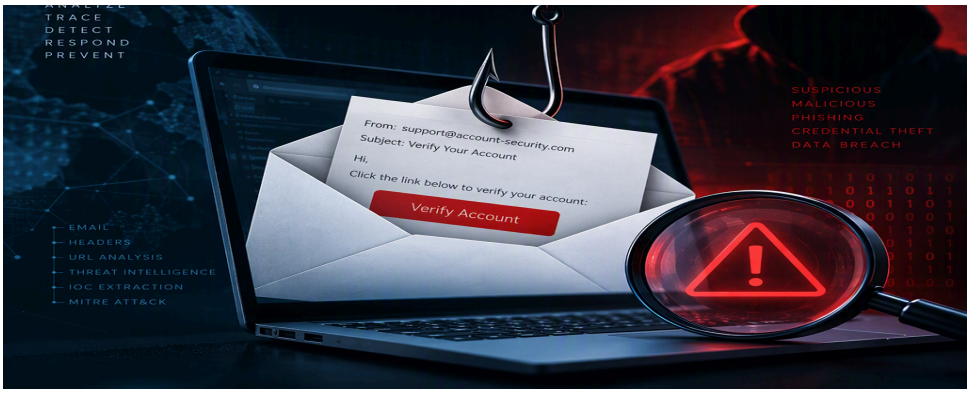


Phishing Email Analysis & Incident Response

Analyst :	Krisha A/P Nandakumar
Day/Date/Time:	Nov 1, 2026 12:00 AM GMT+8
Objective:	Analyze a reported phishing email by inspecting headers, tracing redirect chains safely, extract Indicators of Compromise (IOCs), and map findings to the MITRE ATT&CK framework.
Github Link:	https://github.com/krisha735/soc-phishing-analysis.git

1.0 Executive Summary

Incident Type:	Suspicious Email / Malicious Link Investigation
Severity:	Medium / High
Analyst:	Krisha Nandakumar
Status:	In Progress
Objective:	Analyze a reported phishing email by inspecting headers, tracing redirect chains safely, extract Indicators of Compromise (IOCs), and map findings to the MITRE ATT&CK framework.

2.0 Tools & Technologies Used

Category	**Tools / Services Used**
Environment	Kali Linux VM
Header Analysis	Text Editor, MXToolbox
Threat Intelligence	VirusTotal, URLScan.io
Frameworks	MITRE ATT&CK Enterprise

3.0 Incident Response Steps

Phase 1: Detection & Triage

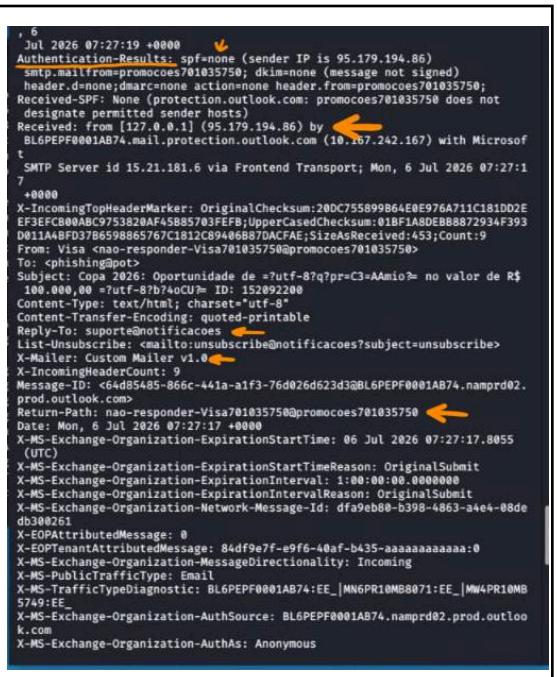
Retrieved authentic raw phishing samples from github for inspection within an isolated Kali Linux environment.

Source Link :	https://github.com/rf-peixoto/phishing_pot/blob/main/email/sample-100.eml

Phase 2: Technical Analysis & Evidence

Header Inspection: Analyzing From display name vs. Return-Path, SPF, DKIM, and DMARC alignment.

From Header:	Visa <nao-responder-Visa70103570 @promocoes70103570>
Return-Path:	nao-responder-Visa70103570 @promocoes70103570
Originating Sender IP	95.179.194.86
Authentication:	SPF=none, DKIM=none (message not signed), DMARC=none
X-Mailer:	Custom Mailer v1.0
Reply-To:	suporte@notificacoes



Phase 3: Indicators of Compromise (IOCs)

Indicator Type	Value	Description / Context
Sender IP	95.179.194.86	Originating MTA server IP
Malicious Domain / Email Domain	promocoes70103570	Fake Visa phishing domain
Reply-To Address	suporte[@]notificacoes	Unmonitored / fraudulent reply-to address
Subject	Copa 2026: Oportunidade de ... no valor de R$ 100.000,00	Phishing email lure subject
Phishing URL	hxxps://cop4asojateosom0-1094100152898[.]us-central1[.]run[.]app/?cid=phishing@pot@hotmail[.]com	Malicious phishing destination URL
Malicious Domain /	cop4asojateosom0-10941001528	Google Cloud Run

Indicator Type	Value	Description / Context
Infrastructure	98.us-central1.run.app	Serverless Instance
Target Tracking Parameter	cid=phishing@pot@hotmail.com	Tracking parameter for victim click rates

Phase 4: URL & Infrastructure Analysis

Cloud Abuse:	Host is utilizing Google Cloud Run (run.app) to bypass standard email gateway web reputation filters.
Victim Tracking:	The URL appends ?cid=phishing@pot@hotmail.com to track specific victim click rates.

Findings using VirusTotal

Analyzed Indicator: Originating IP 95.179.194.86

1. **Detection Score (0 / 92):**
   - No security vendor flagged this IP address as malicious on its last scan.
   - IP 95.179.194.86 belongs to **The Constant Company, LLC (Vultr)**, a legitimate commercial VPS and cloud hosting provider. Newly provisioned or recycled cloud hosting IPs frequently return clean scores because they have not yet accumulated malicious flags.
2. **Infrastructure & ASN Insights:**
   - Identified as commercial VPS infrastructure (AS 20473). This raises the suspicion since threat actors usually utilize cheap, anonymous cloud VPS providers to spin up temporary Mail Transfer Agents (MTAs) for phishing campaigns and remove them immediately afterward.
3. **Passive DNS & Historical Observations:**
   - Historical records show past resolutions to utility and mail domains (securing-mail.com, mailbox.stpettersen.xyz), confirming the IP undergoes frequent reassignments—a classic indicator of shared or rented cloud hosting infrastructure.
4. **Takeaway:**
   - Even when VirusTotal returns a clean detection score (0/92) for a raw originating IP, analysts must never write it off as safe. Threat actors intentionally leverage clean cloud hosting infrastructure (such as Vultr VPS and Google Cloud Run) to evade perimeter IP blocklists. Hence true threat identification was based on correlating header anomalies (X-Mailer: Custom Mailer v1.0), authentication failures (SPF/DKIM none), and destination payload paths.

Findings using URLScan.io

1. **URL & Infrastructure Analysis**

- **Scanned Target URL:** hxxps://cop4asojateosom0-1094100152898[.]us-central1[.]run[.]app/?cid=phishing@pot@hotmail[.]com
- **Destination IP & Hosting:** 34.143.75.2 (AS396982 - Google Cloud Platform)
- **TLS Certificate:** Issued by WR2 (Google Trust Services / Let's Encrypt short-lived cert valid for 3 months).
- **Page Title / Response:** 404 Page Not Found
- **URLScan.io Verdict:** No classification / Unclassified (0 Detections)

2. **SOC Technical Analysis Note (URLScan.io Results)**

- **Page Status 404:** Indicates the container was taken down, expired, or actively blocking scanning bots via user-agent checking / geo-fencing.
- **Serverless Evasion Tactics:** Threat actors host temporary containers on Google Cloud Run to get valid HTTPS certificates and bypass domain reputation filters. Once a phishing run finishes or gets scanned, the container returns 404 or drops traffic.

2.0 MITRE ATT&CK Mapping

Technique ID	Technique Name	Description in Context
T1566.002	Phishing: Spearphishing Link	Adversary delivered phishing email with malicious hyperlink

Containment & Remediation Recommendations

1. Block 192[.]0[.]2[.]1 and login-verify-account[.]com at perimeter firewall and email gateway.
2. Purge matching email IDs across all organization inboxes.
3. Reset user credentials if interaction occurred.
4. Update SIEM rules for domain patterns matching the phishing campaign.

Problem Encountred And Solution

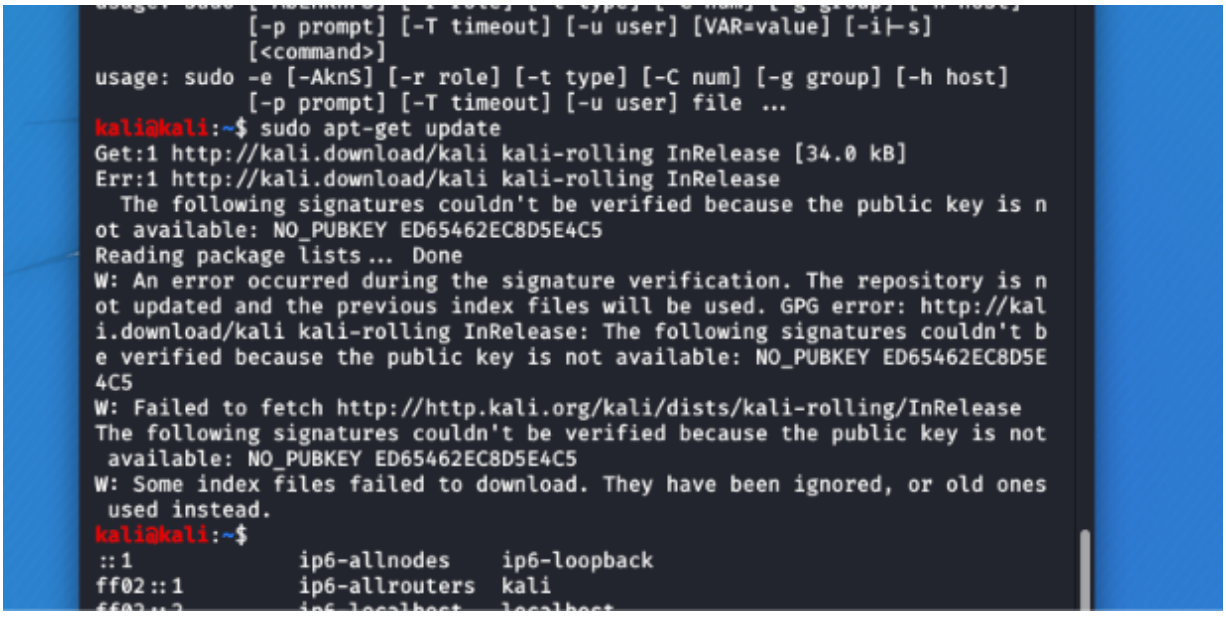
[ID-001] Kali Linux GPG Key Verification Error

Date: Oct 1, 2026 | **Category:** Linux / Package Management | **Tool/OS:** Kali Linux VM

Incident: Kali Linux GPG Key Verification Error Symptoms:
During sudo apt update or sudo apt-get update, the package manager fails with a GPG signature verification error: NO_PUBKEY ED65462EC8D5E4C5

Root Cause: Kali Linux rotated its repository archive signing keys, and the local APT keyring lacks the updated public key required to verify package authenticity.

Solution / Remediation Steps:
1. Fetch and install the updated Kali archive keyring: sudo wget https://archive.kali.org/archive-keyring.gpg -O /usr/share/keyrings/kali-archive-keyring.gpg
2. Refresh the package lists: sudo apt-get update



Question and Answer

Q1: What to look for and why does it matter in header analysis?

Header Tag	What to Look For	Why It Matters
From:	Display name & email	Shows what brand the attacker is impersonating (e.g., Visa).
Return-Path:	Envelope sender	Shows where bounce-back errors are sent (often reveals the real domain).
Authentication-Results:	spf=, dkim=, dmarc=	Microsoft/Google already checked if the IP is authorized; none or fail confirms spoofing.
Bottom Received:	Originating IP address	Identifies the physical server/hoster that sent the email.

Q2: What is X-Mailer & Why SOC Analysts Inspect It

What is X-Mailer?

The X-Mailer header indicates the application or script used to compose and transmit an email. The X- prefix denotes an optional extended header commonly populated by email clients and bulk-sending tools.

Why SOC Analysts Inspect X-Mailer:

1. **Spotting Mass Automated Phishing Tools:** Legitimate corporate users typically send emails via standard desktop or webmail clients (e.g., Outlook, Apple Mail). Threat actors frequently use custom Python, PHP, or Go scripts. Finding X-Mailer: Custom Mailer v1.0 strongly indicates an automated bulk phishing tool rather than a human sender.
2. **Detecting Inconsistencies & Impersonation:** A mismatch between the advertised brand (e.g., Visa) and the sending tool (e.g., PHPMailer or bulk blast scripts) highlights an anomaly.
3. **Attribution & Campaign Tracking:** Phishing kits often leave default X-Mailer strings, aiding analysts in linking separate email alerts to a single threat campaign.
4. **Identifying Compromised Web Servers:** Scripting headers like PHPMailer 5.2 often reveal compromised web servers running unauthorized mailer scripts.

X-Mailer Quick Reference Table

X-Mailer Example	What It Usually Means	Threat Level in Phishing Context
Microsoft Office Outlook 16.0	Standard legitimate email client	Low (unless spoofed or account compromised)
Custom Mailer v1.0	Automated bulk phishing script	High
PHPMailer 6.0	Server-side script (often compromised site)	Medium / High
(Missing / Empty)	Attacker intentionally stripped header	Medium

Ref: [X-Mailer Header Explained | Email Header Analyzer]